



Microsoft Sentinel Analytic Rules Recommendations

AB Nigeria

Contents

1. Executive Summary	2
2. Analytic Rules Recommendations	2
2.1. Purpose and Scope.....	3
3. Proposed Analytic Rules.....	3
3.1. Remote Logon Activities (Success and Failures)	3
3.2. SSH Login.....	4
3.3. SSH Brute Force	5
3.4. Successful VPN Connection	7
4. Rules Requiring Optimization.....	8
4.1. EDR Detection Events with Active Incident IDs.....	9
4.2. Suspicious WithSecure EDR Activity Detected	9
4.3. Suspicious WithSecure ScanFile Activity Detected	10
4.4. Non-Domain Controller Active Directory Replication	10

1. Executive Summary

This report outlines recommendations to strengthen AB Nigeria's Security monitoring and improve the SOC's ability to detect and respond to suspicious activity. The review focused primarily on remote access, authentication, endpoint security, and Active Directory activity, with the aim of improving visibility into potential unauthorized access, credential attacks, lateral movement, and other high-risk security events.

Four new analytic rules are recommended to improve coverage of remote-access activity:

- **Remote Logon Activities,**
- **SSH Login,**
- **SSH Brute Force, and**
- **Successful VPN Connection.**

Together, these rules will provide better visibility into how users and administrators access the environment remotely and help the SOC identify unusual login behaviour, repeated authentication failures, and potentially unauthorized connections.

The assessment also identified opportunities to improve four existing detection rules covering:

- WithSecure EDR,
- suspicious file activity, and
- Active Directory replication.

The recommended changes focus on faster alerting, better incident correlation, reduced duplicate processing, and clearer information for analysts during investigations. For the Active Directory replication rule, additional scoping to confirmed production Domain Controllers is also recommended to improve accuracy and reduce unnecessary alerts.

Before the proposed changes are moved into production, key settings and thresholds should be validated against AB Nigeria's actual security telemetry. This will ensure that the rules are appropriately tuned to the environment and that legitimate security events are not unintentionally missed.

Overall, the recommendations provide a practical way to improve the effectiveness of AB Nigeria's Microsoft Sentinel deployment. Implementing and properly tuning these changes should result in faster detection, fewer unnecessary alerts, better investigation context, and stronger overall visibility across the environment.

2. Analytic Rules Recommendations

This section presents proposed Microsoft Sentinel analytic rules and optimization recommendations intended to enhance AB Nigeria's threat detection, monitoring, and incident response capabilities.

The recommendations focus on improving visibility into remote access activities, authentication attempts, and potentially unauthorized access, while also enhancing the effectiveness of selected existing analytic rules through improved detection frequency, evaluation periods, and environment-specific tuning.

2.1. Purpose and Scope

The goal is to strengthen cybersecurity defenses by identifying, monitoring, and responding to suspicious activities across cloud, identity, endpoint, and remote-access environments. The assessment focuses on remote authentication activity, administrative access, brute-force attempts, endpoint detections, and Active Directory replication activity.

3. Proposed Analytic Rules

The following new analytic rules are recommended to improve detection coverage within the AB Nigeria Microsoft Sentinel environment.

Analytic Rule	Description
Remote Logon Activities (Success and Failures)	Monitors successful and failed remote interactive logons to identify unauthorized access attempts or lateral movement within the environment.
SSH Login	Detects successful SSH login attempts, enabling visibility into remote administrative access to systems.
SSH Brute Force	Identifies multiple failed SSH login attempts from the same source, suggesting a brute-force attack targeting SSH credentials.
Successful VPN Connection	Logs successful VPN connections to track remote user access and detect potential unauthorized connections to the network.

3.1. Remote Logon Activities (Success and Failures)

Description: Detects successful and failed remote interactive logon activity on Windows systems. The rule provides visibility into Remote Desktop authentication activity and can assist in identifying unauthorized remote access attempts or lateral movement within the environment.

Impact / Security Value: Monitoring both successful and unsuccessful remote interactive logons enables the SOC to identify unusual RDP access, repeated

authentication failures, and potentially successful access following failed attempts. This improves visibility into lateral movement and unauthorized administrative access.

Data Source: SecurityEvent

Severity: Medium

Rule Frequency: 15 minutes **Rule Period:** 15 minutes

MITRE ATT&CK Mapping:

- TA0008 Lateral Movement
 - o T1021.001 Remote Services: Remote Desktop Protocol

Entity Mapping:

- Host: Computer
- Account: TargetAccount
- IP: IpAddress

Event grouping:

- Group all events into a single alert

Rule Query:

```
SecurityEvent
| where EventID in (4624, 4625)
| where LogonType == 10
| extend LogonResult = iff(EventID == 4624, "Success", "Failure")
| where isnotempty(IpAddress)
| where IpAddress !in ("-", "127.0.0.1", ":::1")
| project TimeGenerated, Computer, TargetAccount, TargetDomainName,
    IpAddress, LogonResult, EventID, LogonType, LogonTypeName,
    Status, SubStatus, Activity
```

3.2. SSH Login

Description: Detects successful SSH authentication to Linux systems, providing visibility into remote administrative access and enabling the identification of unexpected or unauthorized SSH sessions.

Impact / Security Value: Successful SSH logons can provide administrative access to critical Linux infrastructure. Monitoring these events helps establish visibility into remote administration and supports investigation of suspicious access from unfamiliar source addresses or accounts.

Data Source: Syslog

Severity: Medium

Rule Frequency: 15 minutes **Rule Period:** 15 minutes

MITRE ATT&CK Mapping:

- TA0008 Lateral Movement
- o T1021.004 Remote Services: SSH

Entity Mapping:

- Host: Computer
- Account: UserName
- IP: SourceIP

Event grouping:

- Group all events into a single alert

Rule Query:

```
CommonSecurityLog
| where DeviceVendor =~ "Fortinet"
| where DeviceProduct =~ "Fortigate"
// | where DeviceEventClassID == "32002"
| where DeviceEventCategory =~ "event:system"
| where DeviceAction =~ "login"
// | where EventOutcome =~ "failed"
| extend LoginMethod = extract(
    @"FTNTFGTmethod=([^;]+)",
    1,
    toString(AdditionalExtensions)
)
| where LoginMethod =~ "ssh"
| project
    TimeGenerated,
    DestinationUserName,
    SourceIP,
    DestinationIP,
    LoginMethod,
    EventOutcome,
    Reason,
    Activity,
    DeviceAction,
    Message,
    Computer,
    DeviceExternalID
| order by TimeGenerated desc
```

3.3. SSH Brute Force

Description: Detects repeated failed SSH authentication attempts originating from the same source IP address within a short period. A high concentration of failed attempts may indicate password guessing, credential brute forcing, or attempts to gain unauthorized administrative access.

Impact / Security Value: Early identification of SSH brute-force activity allows the SOC to investigate and potentially block malicious source addresses before credentials are

successfully compromised. It also highlights externally exposed or improperly protected SSH services.

Data Source: Syslog

Severity: Medium

Rule Frequency: 5 minutes **Rule Period:** 10 minutes

MITRE ATT&CK Mapping:

- TA0006 Credential Access
 - o T1110.001 Brute Force: Password Guessing

Entity Mapping:

- Host: Computer
- Account: TargetedUsers
- IP: SourceIP

Event grouping:

- Group all events into a single alert

Rule Query:

```
CommonSecurityLog
| where DeviceVendor =~ "Fortinet"
| where DeviceProduct =~ "Fortigate"
| where DeviceEventClassID == "32002"
| where DeviceEventCategory =~ "event:system"
| where DeviceAction =~ "login"
| where EventOutcome =~ "failed"
| extend LoginMethod = extract(
    @"FTNTFGTmethod=([^;]+)",
    1,
    toString(AdditionalExtensions)
)
| where LoginMethod =~ "ssh"
| summarize
    FailedAttempts = count(),
    FirstAttempt = min(TimeGenerated),
    LastAttempt = max(TimeGenerated),
    TargetedAccounts = make_set(DestinationUserName, 20),
    Reasons = make_set(Reason, 10),
    Messages = make_set(Message, 10)
    by SourceIP, Computer, bin(TimeGenerated, 10m)
| where FailedAttempts >= 5
| project
    FirstAttempt,
    LastAttempt,
    SourceIP,
    Computer,
    FailedAttempts,
    TargetedAccounts,
    Reasons,
```

3.4. Successful VPN Connection

Description: Detects successful VPN connection events to provide visibility into remote user access to the organization's network.

Impact / Security Value: Monitoring successful VPN activity enables analysts to identify potentially unauthorized remote access and provides useful context during investigations involving compromised accounts, unusual source addresses, or remote access outside expected patterns.

Data Source: CommonSecurityLog

Severity: Low

Rule Frequency: 15 minutes **Rule Period:** 15 minutes

MITRE ATT&CK Mapping:

- TA0001 Initial Access
 - o T1133 External Remote Services

Entity Mapping:

- Account: SourceUserName
- IP: SourceIP

Event grouping:

- Group all events into a single alert

Implementation Note: VPN products populate CommonSecurityLog fields differently. Validate the success indicators and vendor-specific activity values against the VPN telemetry ingested in the AB Nigeria workspace.

Rule Query:

```
CommonSecurityLog
| where DeviceVendor =~ "Fortinet"
| where DeviceProduct =~ "Fortigate"
| where DeviceEventCategory =~ "event:vpn"
| where DeviceAction =~ "tunnel-up"
|   or Activity =~ "tunnel-up"
|   or SimplifiedDeviceAction =~ "tunnel-up"
| where Reason =~ "tunnel established"
| extend
    TunnelIP = extract(@"FTNTFGTtunnelip=([^;]+)", 1, AdditionalExtensions),
    TunnelType = extract(@"FTNTFGTtunneltype=([^;]+)", 1,
AdditionalExtensions),
    TunnelID = extract(@"FTNTFGTtunnelid=([^;]+)", 1, AdditionalExtensions),
    VPNGroup = extract(@"FTNTFGTgroup=([^;]+)", 1, AdditionalExtensions),
    SourceCountry = extract(@"FTNTFGTsrccountry=([^;]+)", 1,
AdditionalExtensions),
    FortiClientUID = extract(@"FTNTFGTfctuid=([^;]+)", 1,
AdditionalExtensions),
```

```

    LogDescription = extract(@"FTNTFGTlogdesc=([^\;]+)", 1,
AdditionalExtensions)
| where TunnelType =~ "ssl-tunnel"
| project
    TimeGenerated,
    Computer,
    User = DestinationUserName,
    SourceIP = DestinationIP,
    TunnelIP,
    VPNGroup,
    SourceCountry,
    TunnelType,
    TunnelID,
    FortiClientUID,
    LogDescription,
    Reason,
    DeviceAction
| order by TimeGenerated desc

```

4. Rules Requiring Optimization

The following existing analytic rules are recommended for configuration or query optimization. These changes are intended to improve detection timeliness and reduce unnecessary false-positive alerts.

Analytic Rule	Recommendation	Expected Impact
EDR Detection Events with Active Incident IDs	Adjust the rule frequency and evaluation period to at most 15 minutes.	Faster detection and response to active endpoint incidents.
Suspicious WithSecure EDR Activity Detected	Adjust the rule frequency and evaluation period to at most 15 minutes.	Reduces alerting latency for suspicious EDR activity.
Suspicious WithSecure ScanFile Activity Detected	Adjust the rule frequency and evaluation period to at most 15 minutes.	Improves timeliness of suspicious ScanFile detections.
Non-Domain Controller Active Directory Replication	Add a reference list of Domain Controller hostnames to the rule query.	Reduces false positives while preserving detection of suspicious replication activity.

4.1. EDR Detection Events with Active Incident IDs

Description: Detects WithSecure EDR events associated with active incident identifiers so that endpoint incidents requiring investigation can be surfaced in Microsoft Sentinel. The analytic rule is currently set to an evaluation period of 5 hours.

Optimization Recommendation: Adjust the analytic rule frequency and evaluation period to 15 minutes. Retain the existing detection logic unless subsequent validation identifies a query-specific issue.

Impact / Security Value: A shorter evaluation cycle reduces the delay between an active WithSecure incident and the corresponding Sentinel alert, enabling faster triage, investigation, and containment.

Data Source: WsSecurityEvents_CL

Severity: Retain existing severity

Rule Frequency : 15 minutes

Rule Period : 15 minutes

Entity Mapping: Retain existing entity mappings

Event grouping: Retain existing event-grouping configuration

Rule Query: Retain the existing KQL. No query modification is required for this scheduling optimization.

4.2. Suspicious WithSecure EDR Activity Detected

Description: Detects suspicious endpoint activity reported by WithSecure EDR and surfaces the activity in Microsoft Sentinel for centralized monitoring and investigation.

Optimization Recommendation: Adjust the analytic rule frequency and evaluation period to 15 minutes. Retain the existing detection logic unless subsequent validation identifies a query-specific issue.

Impact / Security Value: Reducing the evaluation interval improves the timeliness of alerts for suspicious endpoint activity and allows the SOC to investigate potentially malicious behavior sooner.

Data Source: WsSecurityEvents_CL

Severity: Retain existing severity

Rule Frequency: 15 minutes Rule Period: 15 minutes

Entity Mapping: Retain existing entity mappings

Event grouping: Retain existing event-grouping configuration

Rule Query: Retain the existing KQL. No query modification is required for this scheduling optimization.

4.3. Suspicious WithSecure ScanFile Activity Detected

Description: Detects suspicious WithSecure ScanFile activity and provides centralized visibility in Microsoft Sentinel for investigation of potentially malicious file-related events.

Optimization Recommendation: Adjust the analytic rule frequency and evaluation period to 15 minutes. Retain the existing detection logic unless subsequent validation identifies a query-specific issue.

Impact / Security Value: A shorter rule schedule provides more timely visibility into suspicious file-scanning activity and reduces delays in initiating investigation and response.

Data Source: WsSecurityEvents_CL

Severity: Retain existing severity

Rule Frequency: 15 minutes **Rule Period:** 15 minutes

Entity Mapping: Retain existing entity mappings

Event grouping: Retain existing event-grouping configuration

Rule Query: Retain the existing KQL. No query modification is required for this scheduling optimization.

4.4. Non-Domain Controller Active Directory Replication

Description: Detects potential attempts by non-computer accounts to retrieve or synchronize Active Directory objects by using directory replication services. This activity can indicate abuse of directory replication permissions and credential theft through DCSync-like behavior.

Optimization Recommendation: Enter a reference list of AB Nigeria Domain Controller hostnames in the rule query and scope the underlying SecurityEvent searches to those systems. Replace the sample DC names below with the production Domain Controller FQDNs.

Impact / Security Value: Scoping the query to known Domain Controllers reduces false-positive alerts and unnecessary event processing while preserving visibility into suspicious directory replication activity performed by non-machine accounts.

Data Source: SecurityEvent

Severity: High

MITRE ATT&CK Mapping:

- TA0006 Credential Access
 - o T1003.006 OS Credential Dumping: DCSync

Entity Mapping:

- Account: Account

- Host: Computer
- IP: IPAddress

Rule Query:

```
// Enter a reference list of hostnames for AB Nigeria Domain Controllers
let DCServersList = dynamic (["DCABN01.abnigeria.com",
"DCABN02.abnigeria.com"]);
let AllowedReplicationAccounts = dynamic([ "ABNIGERIA\\MSOL_1c5826f8d2f9",
"ABNIGERIA\\tsadminuser" ]);
SecurityEvent
//| where Computer in~ (DCServersList)
| where EventID == 4662 and ObjectServer == "DS"
| where AccountType != "Machine"
| where Properties has "1131f6aa-9c07-11d1-f79f-00c04fc2dcd2"
    or Properties has "1131f6ad-9c07-11d1-f79f-00c04fc2dcd2"
    or Properties has "89e95b76-444d-4c62-991a-0facbeda640c"
| project TimeGenerated, Account, Activity, Properties, SubjectLogonId,
Computer
| join kind=leftouter (
    SecurityEvent
    //| where Computer in (DCServersList)
    | where EventID == 4624 and LogonType == 3
    | where AccountType != "Machine"
    | project TargetLogonId, IPAddress, Computer
) on $left.SubjectLogonId == $right.TargetLogonId
    and $left.Computer == $right.Computer
| project-reorder TimeGenerated, Computer, Account, IPAddress
| extend HostName = tostring(split(Computer, ".")[0]),
    DomainIndex = toint(indexof(Computer, "."))
| extend HostNameDomain = iff(DomainIndex != -1,
    substring(Computer, DomainIndex + 1), Computer)
| extend AccountNTDomain = tostring(split(Account, "\\")[0]),
    AccountName = tostring(split(Account, "\\")[1])
| where Account !in~ (AllowedReplicationAccounts)
```